



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



ThreatsDay Bulletin: Worm Code Leaked, AI Agent Phished, Claude Code Patch + 28 New Stories

Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-11
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | ThreatsDay Bulletin: Worm Code Leaked, AI Agent Phished, Claude Code Patch + 28 New Stories - Vulnerability Threat Intelligence Report

Published: 2026-06-11 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

ThreatsDay Bulletin: Worm Code Leaked, AI Agent Phished, Claude Code Patch + 28 New Stories

1. Executive Summary

The 11 June 2026 ThreatsDay bulletin from The Hacker News consolidates a high-tempo week of identity theft, supply-chain abuse, agentic-AI exposure, endpoint-defense degradation, and commodity malware activity. The most consequential defender theme is not a single exploit chain; it is the continued convergence of stolen credentials, trusted development infrastructure, remote management tooling, browser extensions, and AI-enabled workflows into attack paths that can bypass traditional perimeter controls.

Lost Boys Cyber assesses this bulletin as operationally relevant for organizations that run public software-development pipelines, Microsoft Exchange or hybrid mail routing, EDR-managed Windows fleets, browser-extension-heavy workforces, ecommerce storefronts, and AI agent or GitHub Actions automation. The highest-priority issues for immediate review are the Miasma/Shai-Hulud supply-chain toolkit leak, the Claude Code GitHub Action environment-exposure bug, the Ghost-Sender Exchange spoofing condition, EDRChoker-style telemetry throttling, and credential-theft ecosystems anchored by infostealers, loaders, RATs, and malicious packages.

The bulletin includes one named CVE, CVE-2026-49494 in Comodo Internet Security's Inspect.sys firewall driver, assessed in public reporting as remotely triggerable denial of service with a single TCP/IP packet and unpatched as of the cited article. The broader defensive requirement, however, is identity and pipeline hardening: reduce token blast radius, monitor for package/dependency drift, restrict agent access to secrets, validate mail-flow assumptions, and hunt for signs that endpoint telemetry, browser data, or CI/CD environments are being abused.

Priority	Defensive Focus	Why It Matters	Initial Action
Critical	CI/CD and AI-agent secret exposure	The Claude Code Action case shows untrusted GitHub content can influence AI workflows and expose runner environment secrets if file-read boundaries are incomplete.	Upgrade affected actions, remove standing secrets where possible, rotate exposed tokens, and restrict agent permissions.
Critical	Software supply-chain abuse	Miasma/Hades and SStar Agent demonstrate credential theft, registry abuse, malicious npm dependencies, and AI-coding-tool config poisoning.	Audit package lockfiles, developer tokens, GitHub Actions, npm/PyPI/RubyGems publishing rights, and developer workstation telemetry.
High	Identity theft and browser/session compromise	Flashpoint reported 11.1M infostealer-infected devices and 3.3B identity artifacts circulating in illicit markets.	Expand identity telemetry, revoke stale sessions, enforce phishing-resistant MFA, and monitor impossible travel / token reuse.
High	EDR degradation without exploit	EDRChoker and service/DLL ACL tampering show attackers can degrade security tooling using OS policy and configuration abuse.	Monitor QoS policy creation, service failures, ACL changes to system libraries, and EDR agent connectivity gaps.
High	Mail spoofing / trusted comms abuse	Ghost-Sender shows certain Exchange Online or hybrid/external-MX configurations can allow spoofed internal or external	Validate mail-routing architecture, perform controlled spoof tests, and review anti-spoof controls beyond

		senders.	SPF/DKIM/DMARC.
--	--	----------	-----------------

2. Intelligence Requirement

This report addresses the following intelligence requirement:

Requirement	Analyst Response
Primary question	Which items in the 11 June 2026 ThreatsDay bulletin create material exposure for enterprise defenders, and what should be done first?
Scope	Public reporting from The Hacker News and linked primary sources concerning vulnerabilities, malware, AI-agent risk, supply-chain threats, identity compromise, and defensive bypass techniques.
Audience	Security leadership, SOC managers, detection engineers, threat hunters, identity administrators, endpoint engineers, and DevSecOps owners.
Decision supported	Prioritization of review, mitigation, detection, and hunting work across identity, CI/CD, package supply chain, endpoint, mail, and browser-extension surfaces.
Time horizon	Immediate triage over 0-7 days, control validation over 7-30 days, and sustained hardening over 30-90 days.

The practical requirement is to convert a broad weekly threat summary into a prioritized defensive queue. Lost Boys Cyber does not recommend treating every item as equal. Items that affect credential material, developer infrastructure, trusted agents, mail authenticity, endpoint telemetry, or ecommerce payment collection should receive priority because they can convert ordinary user or developer trust into enterprise-wide compromise.

Assumptions used in this assessment:

- The defended environment uses common enterprise tooling: Microsoft 365 or hybrid mail, GitHub or comparable CI/CD, EDR on Windows endpoints, browser extensions, npm/PyPI dependencies, and cloud or SaaS identity providers.
- The source article is a secondary roundup; linked vendor, researcher, and government sources should be used for final remediation specifics.
- No client-specific telemetry, asset inventory, or exploit reproduction was available for this draft; detection and hunting content is therefore written as adaptable logic rather than environment-specific production rules.

3. Source Review and Confidence

Source	Contribution	Reliability	Confidence	Notes
The Hacker News, "ThreatsDay Bulletin: Worm Code Leaked, AI Agent Phished, Claude Code Patch + 28 New Stories"	Primary intake source and consolidated timeline.	B	Medium	Secondary roundup; useful for scoping and pivoting to primary sources.
Flashpoint infostealer analysis	Identity-theft scale: 11.1M infected devices and 3.3B identity artifacts.	B	Medium-High	Vendor research; exact data corpus not independently reproduced.

SafeDep / Sonatype / Endor Labs Miasma-Hades reporting	Supply-chain toolkit, registry abuse, and affected component count.	B	Medium-High	Multiple independent software-supply-chain sources increase confidence.
Microsoft Security blog on Claude Code GitHub Action	CI/CD and AI-agent secret exposure mechanics and patch timeline.	A	High	Vendor-owned technical disclosure for the affected action path.
Varonis OpenClaw agent phishing research	AI-agent social-engineering scenario where an agent forwarded sensitive credentials.	B	Medium	Simulation-based research; direct exploitability depends on deployed agent permissions and validation controls.
InfoGuard Ghost-Sender research	Exchange misconfiguration spoofing condition.	B	Medium	Configuration-specific; requires tenant architecture validation.
Zero Salarium / Binary Defense endpoint-defense bypass research	EDRChoker, EDRStartupHinder, and ACL-based service disruption concepts.	B/C	Medium	Researcher and vendor sources; validate carefully before translating into production detection.
MalwareTech / NVD CVE-2026-49494 references	ComoDoS denial-of-service bug in Comodo Inspect.sys.	B/A	Medium-High	Public PoC plus NVD entry; exploitability assessment limited to public reporting.

Overall confidence is medium-high for the strategic assessment that identity, supply chain, and trusted automation are the dominant defensive themes. Confidence is medium for specific prevalence or exploitation claims unless supported by primary vendor/government reporting. The bulletin includes numerous malware-family and campaign references; this report focuses on the items with the clearest enterprise defensive implications rather than attempting full malware reverse engineering for each family.

Important evidence gaps:

- No sample binaries, package tarballs, packet captures, or client telemetry were analyzed for this task.
- Several linked items describe active malware or suspected nation-state activity but do not publish complete IOCs in the roundup.
- The Ghost-Sender and EDRChoker risks are highly configuration-dependent; organizations should validate control state rather than assume exposure.
- The Claude Code Action issue was patched on 5 May 2026 per Microsoft reporting; residual risk depends on whether workflows pinned or upgraded the fixed version and whether secrets were rotated.

4. Key Findings

Finding	Severity	Confidence	Defensive Implication
Infostealer ecosystems continue to supply enterprise-grade identity material at scale.	High	Medium-High	Session cookies, cloud tokens, browser credentials, and MFA fatigue-prone identities should be treated as breach precursors, not commodity noise.

Miasma/Hades represents a mature software-supply-chain toolkit, not a one-off package compromise.	Critical	Medium-High	Public registries, GitHub repositories, GitHub Actions, developer SSH paths, and AI-coding-tool configuration are all potential operational surfaces.
AI agents and agentic CI/CD tools can be phished or induced to disclose credentials when authority and context validation are weak.	Critical	Medium-High	Agents should be least-privileged identities with explicit approval gates for secret access, external forwarding, code execution, and repository writes.
Ghost-Sender-style Exchange configurations can undermine sender authenticity despite apparent SPF/DKIM/DMARC coverage.	High	Medium	Mail-flow validation must include tenant-specific spoof testing, not only DNS-record compliance checks.
EDRChoker-style QoS throttling and ACL/service manipulation can degrade endpoint telemetry without exploiting a product vulnerability.	High	Medium	SOCs should alert on telemetry absence, QoS policy creation for EDR processes, security-service failures, and suspicious ACL modifications.
Malicious packages and poisoned take-home assignments remain a reliable pathway into developer workstations.	High	Medium	Dependency install events, package provenance, and dev-recruiting lures require dedicated monitoring.
The Comodo Inspect.sys CVE-2026-49494 issue is a targeted availability risk for hosts using Comodo Internet Security.	Medium-High	Medium-High	Identify affected Comodo deployments, watch vendor patch status, and segment or replace vulnerable endpoints where business exposure warrants.
Ecommerce and browser-extension items show continued client-side data theft pressure.	High	Medium	WooCommerce checkout integrity, browser-extension allowlisting, and AI chat data governance should be included in defensive reviews.

The most important analytic conclusion is that attackers are exploiting trust boundaries more than single perimeter vulnerabilities. Trusted package registries, GitHub Actions, browser extensions, RMM tools, email agents, AI coding assistants, mail-routing assumptions, and endpoint management policies are increasingly part of the attack surface. A mature defense program should therefore pair vulnerability remediation with identity governance, telemetry integrity monitoring, software provenance controls, and agent permission management.

Selected bulletin items and defensive relevance:

Bulletin Item	Reported Detail	Enterprise Relevance	Defensive Priority
Flashpoint infostealer analysis	11.1M infected devices and 3.3B credentials/cookies/tokens	Fuels account takeover, cloud token reuse, session hijacking,	High

	circulating.	and downstream ransomware/BEC.	
SilabRAT via Hijack Loader / ClickFix	\$5,000/month MaaS RAT with HVNC, browser-profile cloning, wallet targeting.	Browser profile cloning can bypass device fingerprinting and session controls.	High
Famous Chollima tech-sector intrusions	47% of state-sponsored hands-on-keyboard operations against tech sector in CrowdStrike reporting.	Contractor, hiring, and developer identity controls remain a nation-state target.	High
Miasma / Hades	Supply-chain attack toolkit using GitHub search C2, stolen PATs, registry attacks, GitHub Actions, AI coding config poisoning, SSH lateral movement.	Direct impact to development, CI/CD, package consumption, and token governance.	Critical
SStar Agent	Poisoned npm package in Web3 take-home assessment; Windows/macOS RAT behaviors.	Developer recruitment lures can introduce cross-platform surveillance and exfiltration.	High
Download pumping	npm download-count inflation to make malicious packages appear trustworthy.	Popularity metrics alone are unsafe package trust indicators.	Medium-High
Ghost-Sender	Exchange Online/hybrid plus external MX configuration can allow sender spoofing.	Internal-looking mail can drive payment fraud, credential theft, or agent phishing.	High
MLTBackdoor / GoFlateLoader / Agent Tesla / BLUERABBIT	ClickFix, loaders, infostealers, BOF-capable backdoors, process injection, destructive features.	Common malware delivery remains credential- and persistence-focused.	High
NFCShare	Fake banking updates hosted on GitHub read NFC card data and exfiltrate over WebSocket.	Shows continued abuse of GitHub as a malware-hosting trust surface.	Medium
OpenClaw agent phishing	AI email agent forwarded staging credentials to an external Gmail in simulation.	Agent identity controls and human-equivalent approval workflows are required.	Critical
Claude Code GitHub Action bug	Read tool could access <code>`/proc/self/environ`</code> and expose runner secrets; fixed in v2.1.128.	CI/CD workflows using AI agents must isolate secrets from untrusted content.	Critical
EDRChoker	Windows policy-based QoS throttles EDR agents to 8 bits/sec.	Attackers may blind telemetry without disabling process execution directly.	High
ComoDoS / CVE-2026-49494	Remote kernel OOB primitives likely limited to one-packet crash; unpatched at report time.	Availability risk for Comodo Internet Security deployments.	Medium-High

5. Threat Context

The bulletin reflects five converging threat patterns that defenders should treat as part of a single risk landscape.

Pattern	Observed Examples	Defensive Interpretation
Identity material as primary infrastructure	Infostealers, SilabRAT browser-profile cloning, NFCShare credential/card capture, Agent Tesla SMTP exfiltration.	Attackers increasingly buy or steal authenticated access rather than exploit internet-facing services first.
Developer and package ecosystem compromise	Miasma/Hades, SStar Agent, download pumping, poisoned npm packages, GitHub-hosted malware.	Software-delivery infrastructure is a production attack surface; package trust must be verified continuously.
Trusted automation and AI agents as privileged actors	OpenClaw phishing, Claude Code Action <code>`/proc/self/environ`</code> exposure, AI coding tool config poisoning.	Agents need the same identity governance, approval, and monitoring as human administrators and service accounts.
Defense degradation by configuration abuse	EDRChoker QoS throttling, ACL blocking of Windows Defender/Sysmon, EDRStartupHinder.	Telemetry loss should be a detection event; absence of logs can be an attack signal.
Legitimate tool or platform abuse	NinjaOne RMM, GitHub, browser extensions, Exchange routing, Google Search upload retention settings.	Controls must distinguish authorized business use from suspicious trust abuse.

MITRE ATT&CK mapping is necessarily broad because the source article is a multi-story bulletin. The following mapping captures the most supportable techniques from the reporting and should be tuned to client telemetry.

ATT&CK ID	Technique	Bulletin Evidence	Defensive Use
T1566	Phishing	ClickFix campaigns, Agent Tesla ZIP lures, fake job portals, Russia-focused phishing, agent phishing.	Email, web, and collaboration telemetry hunts.
T1195	Supply Chain Compromise	Miasma/Hades, poisoned npm packages, STX RAT trojanized installers, SStar dependency.	Package, repository, and build-pipeline controls.
T1552	Unsecured Credentials	Claude Code Action reading <code>`/proc/self/environ`</code> , exposed tokens in Meta bug-bounty chain, infostealer artifacts.	Secret scanning, token rotation, and runner isolation.
T1059.001	PowerShell	Cloud Atlas PowerShell scripts, Agent Tesla chain, service/EDR manipulation concepts.	Script-block logging and suspicious command-line detection.
T1055	Process Injection	Agent Tesla staged chain injecting into legitimate Windows applications such as <code>`charmap.exe`</code> .	EDR process-injection and suspicious child-process monitoring.
T1113	Screen Capture	Agent Tesla capability set includes screenshot capture.	Endpoint behavior monitoring.
T1056.001	Keylogging	Agent Tesla and SStar Windows build keyboard	Input-capture behavior and

		monitoring.	suspicious API usage detection.
T1105	Ingress Tool Transfer	Downloaded payloads, BOF loading, fake software/tutorial delivery, GitHub-hosted APKs.	Network/file download correlation.
T1219	Remote Access Software	NinjaOne RMM abuse.	RMM inventory, new agent install detection, and allowlisting.
T1562	Impair Defenses	EDRChoker, EDRStartupHinder, ACL blocking of Defender/Sysmon.	Telemetry integrity and security-service health analytics.
T1041	Exfiltration Over C2 Channel	SStar telemetry endpoint, NFCShare WebSocket exfiltration, BLUERABBIT MinIO exfiltration.	DLP, network egress, and unusual protocol monitoring.
T1090 / T1071	Proxy / Application Layer Protocol	Router.elf DoH C2 and downstream DNS hijacking.	Edge-device DNS and DoH anomaly detection.

Attack scenarios most relevant to enterprise defenders:

- A developer receives a Web3 or engineering take-home assignment, installs a poisoned npm dependency, and the payload collects directory trees, browser artifacts, or repository tokens. If the developer has publish rights or GitHub Actions secrets, the compromise can move from workstation to source control.
- A GitHub issue or pull request containing untrusted content is processed by an AI coding action that can read workflow secrets. Even after patching the specific Claude Code bug, the pattern remains: agent tools must not have ambient access to secrets they do not need.
- An attacker uses stolen session cookies or browser-profile cloning to bypass suspicious-login checks. Traditional password resets may not be sufficient unless active sessions, refresh tokens, and OAuth grants are revoked.
- A phishing email appears to come from an internal sender because the organization's Exchange/hybrid mail routing permits Ghost-Sender-style spoofing. The message asks a human or AI assistant to send credentials, approve a payment, or run a script.
- Post-compromise, the attacker creates Windows QoS rules, modifies ACLs, or breaks service startup dependencies to reduce EDR/Sysmon/Defender visibility. The SOC sees fewer alerts rather than an obvious malware signature.

6. Detection and Hunting

The following detection logic is intended as starting material for SOC adaptation. It focuses on observable behavior rather than vendor-specific IOC lists because the source bulletin covers many campaigns and only some reporting includes public indicators.

Analytic	Telemetry	Goal	Priority
CI/CD agent reading Linux process environment	GitHub Actions runner logs, EDR file events, Linux auditd/eBPF where available	Detect agent or tool access to <code>`/proc/self/environ`</code> , <code>`/proc/*/environ`</code> , or environment files from untrusted workflow contexts.	Critical
GitHub Actions secret exposure / untrusted issue trigger	GitHub audit logs, workflow run metadata	Identify workflows triggered by issue/PR/comment content that also load high-value secrets.	Critical
EDR process QoS throttling	Windows Security, Sysmon,	Detect creation of <code>`New-</code>	High

	PowerShell, process/file/registry telemetry	NetQoSPolicy` or `netsh` QoS policies targeting EDR/AV/Sysmon process names.	
Security-service ACL tampering	Sysmon Event ID 11/13/15, Windows Security 4670/4657, EDR file ACL telemetry	Identify deny ACEs or ownership changes on system libraries and security-service dependencies.	High
Poisoned package install	Package-manager logs, process command line, proxy/DNS, EDR file events	Find unexpected npm/PyPI installs from take-home repos, typosquatted packages, or packages with unusual postinstall behavior.	High
GitHub-hosted malware or APK downloads	Proxy, DNS, EDR browser/download telemetry	Detect APK, script, archive, or binary downloads from unusual GitHub repos tied to banking or recruiting lures.	Medium-High
RMM abuse	Endpoint software inventory, service installation, DNS/proxy	Detect new NinjaOne or other RMM agent installation outside approved deployment channels.	High
Infostealer/RAT delivery chain	EDR process/network, email gateway, browser downloads	Identify ClickFix, ZIP-to-script, PowerShell in-memory execution, suspicious SMTP exfiltration, and process injection.	High

6.1 Sigma: Windows QoS Policy Targeting EDR Processes

title: Suspicious QoS Policy Targeting Security Tool Processes id: 1e0dcf80-0d1c-4cb4-97c1-edrchoker-policy-abuse status: experimental description: Detects command-line attempts to create Windows QoS policies that may throttle EDR, AV, or logging agents as described in EDRChoker-style defense impairment research. author: Lost Boys Cyber date: 2026-06-16 references: - https://www.zerosalarius.com/2026/06/edrchoker-choking-telemetry-stream-block-edr.html logsource: product: windows category: process_creation detection: selection_tool: Image endswith: - '\\powershell.exe' - '\\pwsh.exe' - '\\netsh.exe' selection_qos: CommandLine contains: - 'New-NetQoSPolicy' - 'PolicyStore ActiveStore' - 'ThrottleRateActionBitsPerSecond' - 'qos' selection_security_names: CommandLine contains: - 'edr' - 'defender'

```

- 'sense'
- 'sysmon'
- 'crowdstrike'
- 'falcon'
- 'sentinel'
- 'carbonblack'
- 'tanium'
- 'cylance'
- 'sophos'
- 'elastic'
condition: selection_tool and selection_qos and selection_security_names
falsepositives:
- Rare legitimate network-QoS testing by endpoint engineering teams; validate change ticket and process target.
level: high

```

6.2 KQL: EDRChoker-Style QoS and Security-Service Tampering

```

let SecurityTerms = dynamic(["edr", "defender", "sense", "sysmon", "falcon", "crowdstrike", "sentinel", "carbonblack", "tanium", "sophos", "elastic", "cylance"]);
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("powershell.exe", "pwsh.exe", "netsh.exe", "cmd.exe")
| where ProcessCommandLine has_any ("New-NetQosPolicy", "ThrottleRateActionBitsPerSecond", "PolicyStore ActiveStore", "netsh")
| where ProcessCommandLine has_any (SecurityTerms)
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc

let ProtectedFiles = dynamic(["kernel32.dll", "sysmon.exe", "sysmon64.exe", "MsMpEng.exe", "SenseIR.exe", "SenseNdr.exe", "SenseCncProxy.exe"]);
DeviceFileEvents
| where Timestamp > ago(30d)
| where FileName has_any (ProtectedFiles)
| where ActionType in~ ("FileModified", "FileCreated", "FileDeleted", "FileRenamed", "FilePermissionChanged") or AdditionalFields has_any ("Deny", "ACL", "AccessControl")
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, InitiatingProcessAccountName, InitiatingProcessFileName, InitiatingProcessCommandLine, AdditionalFields
| order by Timestamp desc

```

6.3 KQL: CI/CD Runner Secret and `/proc` Environment Exposure

```

DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has "/proc/" and FolderPath ends with "/environ"
| where InitiatingProcessCommandLine has_any ("claude", "github", "actions", "runner", "node", "python", "bash")
| project Timestamp, DeviceName, ActionType, FolderPath, InitiatingProcessAccountName, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc

DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("ANTHROPIC_API_KEY", "GITHUB_TOKEN", "AWS_SECRET_ACCESS_KEY", "AZURE_CLIENT_SECRET", "/proc/self/environ", "/proc/1/environ")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc

```

6.4 KQL: Suspicious Package Install From Recruiting or Take-Home Repositories

```

let PackageTools = dynamic(["npm", "npm.cmd", "node", "python", "pip", "pip3", "bun", "pnpm", "yarn"]);
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ (PackageTools)
| where ProcessCommandLine has_any ("install", "add", "tw-style-utils", "ambar-src", "postinstall", "github.com", "smart-contract", "take-home", "assessment")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine,

```

```
InitiatingProcessFolderPath, InitiatingProcessCommandLine
| order by Timestamp desc
```

6.5 KQL: GitHub-Hosted APK / Archive / Script Downloads

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any ("github.com", "raw.githubusercontent.com", "objects.githubusercontent.com")
| where RemoteUrl has_any (".apk", ".zip", ".js", ".ps1", ".bat", ".cmd", ".exe", ".dll", ".dylib", ".pkg")
| project Timestamp, DeviceName, InitiatingProcessAccountName, InitiatingProcessFileName,
InitiatingProcessCommandLine, RemoteUrl, RemoteIP
| order by Timestamp desc
```

6.6 Splunk: RMM Installation Outside Approved Channels

```
index=endpoint (process_name=msiexec.exe OR process_name=installer OR process_name=powershell.exe OR
process_name=cmd.exe)
("NinjaOne" OR "NinjaRMM" OR "ninjarmm" OR "NinjaRMMAgent" OR "NinjaRemote")
| stats min(_time) as first_seen max(_time) as last_seen values(user) as users values(parent_process)
as parents values(process) as processes by host
| where NOT match(processes, "(?i)approved_deployment_share|intune|scm|jamf|mdm")
| convert ctime(first_seen) ctime(last_seen)
```

6.7 Threat-Hunting Hypotheses

Hypothesis	Hunt Method	Data Required
A developer endpoint installed a malicious dependency from a lure repository.	Correlate package-manager process events, new package names, postinstall scripts, GitHub clone URLs, and outbound telemetry immediately after installation.	EDR process/file/network, package-manager logs, proxy/DNS.
A CI/CD workflow exposed secrets to an AI action or untrusted PR/issue context.	Identify workflows triggered by issue/PR/comment events that had access to high-value secrets; review runs before fixed Claude Code Action version 2.1.128 where applicable.	GitHub audit logs, workflow YAML, runner telemetry, secret-use logs.
An attacker impaired telemetry instead of disabling tools outright.	Find sudden endpoint log gaps, new QoS policies, failed security-service starts, and ACL changes to security dependencies.	EDR health, Windows event logs, Sysmon, configuration management.
Browser or AI-chat data is leaking via extension abuse.	Inventory Chrome/Edge extensions, compare to allowlist, review permissions and outbound network destinations for AI/chat extensions.	Browser-management telemetry, extension inventory, proxy logs.
Exchange mail-flow architecture permits spoofing despite DNS authentication controls.	Run controlled spoof tests and compare received headers, tenant routing, anti-spoof verdicts, and user-facing warnings.	Exchange message trace, email security gateway logs, header analysis.

7. Recommendations

Priority	Owner	Recommendation	Rationale	Target Window
Critical	DevSecOps / Platform Engineering	Audit GitHub Actions and AI coding-agent workflows for access to repository secrets, `proc` paths, privileged tokens, and untrusted	The Claude Code case demonstrates that agent tools can cross trust boundaries when untrusted content and environment secrets	0-7 days

		PR/issue/comment triggers. Upgrade Claude Code Action to at least v2.1.128 where used.	share a runner.	
Critical	Identity / Cloud Security	Rotate credentials and invalidate sessions for identities with evidence of infostealer exposure, suspicious token use, or developer workstation compromise.	Infostealer markets include cookies and tokens; password reset alone may not clear active session risk.	0-7 days
Critical	AppSec / DevSecOps	Enforce package provenance: lockfiles, signed releases where possible, dependency review, package age/reputation checks, postinstall-script review, and publish-token minimization.	Miasma/Hades, SStar Agent, download pumping, and malicious package campaigns exploit developer trust and registry scale.	0-30 days
High	Messaging / Microsoft 365	Validate whether Exchange Online or hybrid/external-MX configurations are susceptible to Ghost-Sender-style spoofing. Do not rely only on SPF, DKIM, and DMARC pass/fail.	The reported condition can allow sender impersonation that appears trusted to users and agents.	0-14 days
High	Endpoint Engineering / SOC	Monitor for QoS policy creation, security-service ACL tampering, EDR/Sysmon/Defender start failures, and sustained endpoint telemetry gaps.	Defense impairment may present as silence rather than a conventional malware alert.	0-14 days
High	SOC / Threat Hunting	Deploy hunts in Section 6 for CI/CD secret access, suspicious package installs, GitHub-hosted malware downloads, RMM installation, and endpoint telemetry impairment.	The bulletin's highest-risk patterns are observable through behavior-centric telemetry.	0-30 days
High	Browser / SaaS Admins	Enforce browser-extension allowlisting and review AI/chat productivity extensions for permissions, publisher trust, and	Browser extensions can capture AI conversations, credentials, or sensitive business content.	0-30 days

		network destinations.		
Medium-High	Vulnerability Management	Identify Comodo Internet Security deployments and track remediation for CVE-2026-49494 / ComoDoS. Consider segmentation or compensating controls for exposed systems.	Public reporting describes a remotely triggerable crash condition; availability risk is environment-specific.	0-14 days
Medium-High	Ecommerce / Web App Owners	Review WooCommerce checkout integrity, plugin provenance, client-side script changes, and payment-form monitoring.	Skimmer campaigns re-implement legitimate payment validation to remain invisible to victims.	0-30 days
Medium	Governance / Privacy	Review Google Search Services History and AI/upload retention settings for managed accounts.	Uploaded images, files, audio, and video may be retained and used to improve services depending on account configuration.	7-30 days

Operational checklist for the next security standup:

- Confirm whether the organization uses Claude Code GitHub Action or comparable AI coding agents in CI/CD.
- List workflows with privileged secrets and untrusted issue/PR/comment triggers.
- Review developer package-install telemetry for recently introduced packages named in the bulletin where applicable: `tw-style-utils`, `ambar-src`, and related suspicious repositories.
- Run a controlled Exchange spoof validation with approval from messaging and legal teams.
- Check endpoint telemetry health dashboards for unexpected gaps, especially on high-value developer and finance systems.
- Inventory browser extensions with AI/chat, VPN, sidebar, or productivity claims and remove unapproved extensions.
- Confirm whether Comodo Internet Security is deployed anywhere; if yes, prioritize CVE-2026-49494 review.
- Validate RMM agent inventory against approved deployment sources, especially NinjaOne in Brazil-facing or Portuguese-language business units.

8. References

- [1] The Hacker News, "ThreatsDay Bulletin: Worm Code Leaked, AI Agent Phished, Claude Code Patch + 28 New Stories," 2026-06-11. <https://thehackernews.com/2026/06/threatsday-bulletin-worm-code-leaked-ai.html>
- [2] Flashpoint, "How Infostealers Fuel Identity-Based Attacks." <https://flashpoint.io/blog/proactive-defender-guide-infostealers/>
- [3] Group-IB, "New SilabRAT Spotted." <https://www.group-ib.com/blog/silabrat-hijackloader-trojan-malware/>
- [4] CrowdStrike, "2026 Technology Threat Landscape Report." <https://www.crowdstrike.com/en-us/blog/crowdstrike-2026-technology-threat-landscape-report/>
- [5] U.S. Department of Justice, "Justice Department, FBI Disable 13 Websites Backed by Suspected Chinese Agents." <https://www.justice.gov/opa/pr/justice-department-fbi-disable-13-websites-backed-suspected-chinese-agents-sought-sensitive>
- [6] SafeDep, "Inside the Miasma Supply Chain Attack Toolkit." <https://safedep.io/inside-the-miasma-supply-chain-attack-toolkit/>
- [7] Sonatype, "New Shai-Hulud/Miasma Wave Hits Hundreds of npm Packages." <https://www.sonatype.com/blog/new-shai-hulud-miasma-wave-hits-hundreds-of-npm-packages>

- [8] Endor Labs, "Shai-Hulud/Hades Wave Hits PyPI Bioinformatics Packages." <https://www.endorlabs.com/learn/shai-hulud-hades-wave-hits-six-pypi-bioinformatics-packages>
- [9] Iru, "New Cross-Platform RAT SStar Agent Emerges." <https://www.iru.com/blog/sstar-agent>
- [10] Tenable, "How Cyberattackers Inflate Malicious Package npm Download Counts." <https://www.tenable.com/blog/how-cyberattackers-inflate-malicious-package-npm-download-counts>
- [11] InfoGuard Labs, "Ghost-Sender." <https://labs.infoguard.ch/posts/ghost-sender/>
- [12] Varonis, "Making OpenClaw AI Agents Fall for Phishing." <https://www.varonis.com/blog/openclaw-phishing>
- [13] Zero Salarium, "EDRChoker: Choking Telemetry Stream to Block EDR." <https://www.zerosalarium.com/2026/06/edrchoker-choking-telemetry-stream-block-edr.html>
- [14] Binary Defense, "Windows Defender ACL Blocking: A Silent Technique With Serious Impact." <https://binarydefense.com/resources/blog/windows-defender-acl-blocking-a-silent-technique-with-serious-impact>
- [15] Microsoft Security, "Securing CI/CD in an Agentic World: Claude Code GitHub Action Case." <https://www.microsoft.com/en-us/security/blog/2026/06/05/securing-ci-cd-in-agentic-world-claude-code-github-action-case/>
- [16] NVD, "CVE-2026-49494." <https://nvd.nist.gov/vuln/detail/CVE-2026-49494>
- [17] MalwareTech, "Exploiting a Remote Kernel Vulnerability in Comodo Internet Security." <https://malwaretech.com/2026/06/exploiting-a-remote-kernel-vulnerability-in-comodo-internet-security.html>
- [18] Cato Networks, "NinjaOne RMM Abuse Chain Detailed." <https://www.catonetworks.com/blog/cato-ctrl-previously-undocumented-ninjaone-rmm-abuse-chain/>
- [19] G DATA, "Browser Add-ons Spy on AI Chats." <https://blog.gdatasoftware.com/2026/06/38428-browser-addons-spy-on-ai-chats>
- [20] Binary Defense, "BLUERABBIT: A Golang-Based Backdoor With Ransomware and Destructive Capabilities." <https://binarydefense.com/resources/blog/bluerabbit-a-golang-based-backdoor-with-ransomware-and-destructive-capabilities>